

HTTP — Hypertext Transfer Protocol

Servicio

HTTP (Hypertext Transfer Protocol)

Puerto por defecto

80/TCP

Descripción

HTTP es el protocolo de comunicación de la capa de aplicación sobre el que se basa la World Wide Web. Estandarizado en RFC 9110 (2022, que reemplaza RFC 7230-7235 y 2616), define cómo los clientes (navegadores, APIs) solicitan recursos y cómo los servidores responden. Opera sin cifrado: los datos viajan en texto plano entre cliente y servidor. HTTP/1.1, HTTP/2 y HTTP/3 son las versiones actuales, aunque el uso en texto plano (no HTTPS) se considera inseguro.

Riesgos de seguridad

- **Transmisión sin cifrado:** Todos los datos (formularios, cookies de sesión, tokens) viajan en claro y pueden ser interceptados.
- **Aplicaciones web vulnerables:** Inyección SQL, XSS, CSRF, RCE y otras vulnerabilidades OWASP Top 10 son explotables a través de HTTP.
- **Información expuesta en cabeceras:** Cabeceras como `Server`, `X-Powered-By` revelan tecnologías y versiones del servidor.
- **Falta de autenticidad del servidor:** Sin TLS, no hay forma de verificar que el servidor es legítimo (facilitando phishing y suplantación).
- **Cookie hijacking:** Las cookies sin el flag `Secure` transmitidas por HTTP pueden ser robadas en la red.
- **Downgrade attacks:** Un atacante puede forzar que una conexión HTTPS degrade a HTTP si no se implementa HSTS.

Escenarios de ataque

1. **Intercepción de sesión en red pública:** En una red WiFi sin cifrado, un atacante captura el tráfico HTTP y roba cookies de sesión activas (sidejacking).
2. **Inyección SQL a través de formularios web:** Parámetros no validados en la aplicación permiten al atacante extraer la base de datos completa.
3. **Cross-Site Scripting (XSS):** Entrada de usuario no saneada permite inyectar scripts maliciosos que se ejecutan en el navegador de otros usuarios.
4. **SSL Stripping:** El atacante intercepta la conexión inicial HTTP y evita la redirección a HTTPS, manteniendo la comunicación sin cifrar.

5. **Directory traversal:** Solicitudes manipuladas como GET `/../../etc/passwd` exponen archivos del sistema si el servidor web no está correctamente configurado.

Mitigaciones recomendadas

- **Migrar a HTTPS (puerto 443)** con certificado TLS válido para todo el tráfico.
- Implementar **HSTS** (Strict-Transport-Security) con `preload` para forzar conexiones seguras.
- Redirigir automáticamente todo tráfico HTTP (80) a HTTPS (443).
- Sanitizar y validar toda entrada de usuario (prevención OWASP Top 10).
- Eliminar cabeceras informativas del servidor (Server, X-Powered-By).
- Configurar cabeceras de seguridad: Content-Security-Policy, X-Frame-Options, X-Content-Type-Options.
- Aplicar WAF (Web Application Firewall) para filtrar tráfico malicioso.
- Mantener el servidor web (Apache, Nginx, etc.) y sus dependencias actualizados.

Nivel de exposición

Medio (*Alto si maneja datos sensibles o autenticación sin HTTPS*)

Referencias

- Fielding, R. et al. *RFC 9110 — HTTP Semantics*. IETF, 2022.
<https://www.rfc-editor.org/rfc/rfc9110>
- OWASP. *Web Security Testing Guide (WSTG)*. <https://owasp.org/www-project-web-security-testing-guide/>
- OWASP. *OWASP Top 10 — 2021*. <https://owasp.org/www-project-top-ten/>
- NIST. *SP 800-44 — Guidelines on Securing Public Web Servers*.
<https://csrc.nist.gov/publications/detail/sp/800-44/ver-2/final>